

Relatório CIPHER

— Jeffrey Assistant

Relatório de Auditoria de Segurança

Fases Audidadas: P0 – P5

Stack: Python 3.14 / Docker / LangGraph + OpenAI Agents SDK 0.22 / mcp==2.1.1 / FastAPI / PostgreSQL 16 +
pgvector / Redis 7.2 / n8n 2.36 / Ollama local

Data: 19/09/2026

Severidade	Quantidade	
CRÍTICA	5	
ALTA	5	
MÉDIA	4	
BAIXA	5	
INFORMATIVA	5	

Total de Achados: 29

Distribuição: CRÍTICA: 5 | ALTA: 5 | MÉDIA: 4 | BAIXA: 5 | INFORMATIVA: 5

RESUMO EXECUTIVO

Foram auditados 29 achados em código P0-through-P5 do project Jeffrey 1.6.0-jarvis-100. A distribuição de severidade é a seguinte:

- CRÍTICA: 5
- ALTA: 5
- MÉDIA: 4
- BAIXA: 5
- INFORMATIVA: 5

PONTOS FORTES

- ✓ CIPHER-001: auth bypass via user_role — corrigido
- ✓ CIPHER-002: WindowsSelectorEventLoop mitigado no Docker
- ✓ CIPHER-019: HITL REST com OAuth guard implementado
- ✓ MCP Server stateless com discovery cache TTL 300s
- ✓ Content Guard M2/M3/M4: redaction PII + Fernet masking + tool sanitization
- ✓ RBAC role resolvido server-side
- ✓ AuditLog captura events HITL e policy decisions
- ✓ CLI desacoplado da API com commands independentes
- ✓ Docker Compose production configs presentes
- ✓ Environment isolation: .env.prod vs .env.example dev separados

PONTOS FRACOS

- `_RUNNING_TASKS` dict em memória: tasks perdidas em restart do Docker
- OAuth Google (calendar/email): stubs — falha silenciosa
- `smoke_test`: 5/7 com Ollama offline — 2 = infra, não código
- MCPClient stdio: processo filho não destruído no shutdown
- Timeout ausente em chamada externa a MCP, n8n, Ollama
- Exceção silenciada em `content_guard.py` (except: pass)
- Tasks `create_task()` sem referência mantida — garbage collected
- OAuth Google stubs: falham silenciosamente sem erro claro
- IDOR em GET `/chat/status/{thread_id}`: usuário pode ver task de outro
- Permissão HITL approval: usuário qualquer pode decidir aprovação
- Chaves API hardcoded em `scripts/`: se repositório ficar público, keys expostas
- Input user ao LLM sem `content_guard` validation em endpoint chat POST
- MCP tool input_schema: servidor confia no cliente, não valida schema
- AuditLog: grava depois da execução — se tool falha entre log = sem registro
- n8n bridge offline: fallback não definido — crash silencioso
- Hardcoded secrets em `scripts/`: se repositório ficar público, keys expostas
- Event loop WindowsSelector vs POSIX no Docker multi-arch
- Rate limiter statefulness: se Redis reiniciar, decisions se perdem

TABELA RESUMO DOS ACHADOS

Severidade	Quantidade
CRÍTICA	5
ALTA	5
MÉDIA	4
BAIXA	5
INFORMATIVA	5

RECOMENDAÇÕES PRIORIZADAS

P1 (Crítica/Alta — Corrigir Agora):

1. Corrigir execucao silenciada em content_guard
2. Fixar _RUNNING_TASKS task accumulation
3. Implementar OAuth Google real (calendar/email)
4. Fixar IDOR em GET /chat/status/{thread_id}
5. Permitir HITL approval apenas para admin

P2 (Média — Proximo Sprint):

1. Adicionar timeouts em chamadas externas
2. Implementar validação de schema MCP do lado servidor

P3 (Baixa/Informativa — Backlog):

1. Atualizar numbering de comentarios em metrics.py
2. Melhorar mensagens de erro CLI para usuario final
3. Limpar findings anteriores verificados como resolvidos

Esforco Estimado P1: ~24 horas | P2: ~12 horas | P3: ~4 horas

RISCOS LATENTES

- `_RUNNING_TASKS` dict persistente em producao com Docker restart
- OAuth Google stubs: usuario tenta usar calendar/email, ferramenta falha silenciosamente
- Dependency upgrades: mcp 2.1.1 vs versao mais recente pode conter security fixes nao aplicados
- Redis/Postgres nao subidos no smoke_test: misleading que o problema e de infra e nao codigo
- Content Guard patterns fixas: novas vectors de prompt injection podem burlar os 33 padroes existentes
- MCPClient stdio process leak: cada execution de chat sem cleanup correto consome descriptor de processo
- AuditLog gap: se ferramenta falhar apos `begin_log` mas antes `end_log` = evento perdido sem rastro
- Hardcoded secrets em scripts/: se repositorio ficar publico, keys expostas imediatamente
- Event loop WindowsSelector vs POSIX no Docker multi-arch: comportamentos diferentes entre platforms
- Rate limiter statefulness: se Redis reiniciar, decisions de rate limit se perdem e ha burst possibility

ISSUES PARA GITHUB (resumido)

1. [CIPHER] Excecao silenciada em content_guard.py — prompt injection nao detectado
2. [CIPHER] _RUNNING_TASKS task accumulation em restart do Docker
3. [CIPHER] OAuth Google stubs — calendar/email nao funcionais
4. [CIPHER] IDOR em GET /chat/status/{thread_id} — usuario pode ver task de outro
5. [CIPHER] HITL approval qualquer usuario pode aprovar/rejeitar

Fim do Relatório CIPHER — Jeffrey Assistant

Metodologia: auditoria linha-a-linha. Findings anteriores validados. Ambiente: venv Python isolado.